

Miroir

Plan de gouvernance des données

LE PROBLÈME

Une *condition*, pas une formalité.

Miroir vend un outil aux conseillers en image, qui préparent une proposition en minutes au lieu d'heures. La donnée appartient à leurs clients finals, à des niveaux de sensibilité différents.

*Sans confiance dans ce traitement, pas de clients. Et pour une jeune entreprise, *perdre* cette confiance, c'est cesser d'exister.*

LE PÉRIMÈTRE

Quatre familles, *jamais une.*

Les traiter comme un pool unique serait la première erreur de gouvernance. Le plan les garde distinctes.

PERSONNEL

Profils clients finals

Saison colorimétrique, morphologie, archétypes, budget, taille. Les mensurations approchent les catégories particulières du RGPD.

RESTREINT

COMPORTEMENTAL

Signaux d'usage

Décisions de retenir ou d'écarter, rattachées à un client pseudonymisé. Alimentent le ré-entraînement hebdomadaire.

CONFIDENTIEL

NON-PERSONNEL

Catalogue produit

Jeu de données public et ses embeddings d'images. Non-personnel, mais lié par des conditions de propriété intellectuelle.

INTERNE

ACTIF MÉTIER

Modèles ML

Artefacts du re-ranker versionnés dans le registre de modèles. Leur comportement doit rester documenté et imputable.

INTERNE

Cinq principes, *un cadre*.

- 1

Décision humaine finale

Rien n'atteint un client final automatiquement. Le modèle suggère, le conseiller choisit. Cela ne peut être désactivé.
- 2

Minimisation

Si un champ est collecté, l'entreprise peut dire pourquoi. Un attribut optionnel n'est gardé que s'il est montré qu'il améliore les recommandations.
- 3

Traçabilité par défaut

Tout ce qui part en production, modèle, schéma ou politique, laisse une trace écrite dans le dépôt comme décision signée.
- 4

Qualité instrumentée

La qualité est contrôlée dans le pipeline, pas validée à l'œil. Une barrière automatique arrête un ré-entraînement sur données défectueuses, sans contournement manuel.
- 5

Transparence

Le modèle servi porte une fiche publique indiquant ce qu'il fait, où il échoue et sur quoi il a été entraîné, mise à jour à chaque promotion.

CADRE RÉGLEMENTAIRE

- RGPD & Loi Informatique et Libertés*

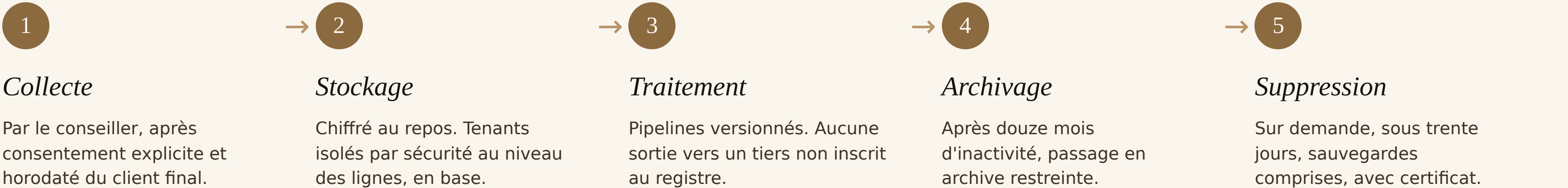
Base légale, conservation et droits des personnes pour les profils et les signaux.
- AI Act, risque limité*

Devoirs de transparence et de documentation, pas les obligations lourdes du risque élevé.
- Code de la consommation*

Information pré-contractuelle et transparence algorithmique.
- Écartés avec raison : NIS2 (pas une entité essentielle), hébergement de santé (les mensurations n'en relèvent pas), ISO 27001 (objectif de seconde année).

CYCLE DE VIE & QUALITÉ

De la collecte *à l'effacement.*



La qualité se mesure

Des attentes automatiques contrôlent la donnée à chaque exécution ; une exécution qui échoue ne se poursuit pas. Chaque contrôle laisse une trace : la mesure peut être reconstruite après coup.

Le catalogue, un levier

Tenu dans le dépôt avec le code, il documente chaque table par propriétaire, source et sensibilité. Il raccourcit le chemin de l'idée à la fonctionnalité et fixe le sens des termes.

Deux rôles, *distincts*.

DONNÉE DES CLIENTS FINALS

Miroir, sous-traitant

Le conseiller décide pourquoi et comment : il est responsable de traitement. Miroir agit sur instructions documentées, au titre de l'article 28.

COMPTES & FACTURATION DES CONSEILLERS

Miroir, responsable

Miroir décide de la finalité pour ces traitements, et en est donc responsable. Garder les deux rôles distincts protège l'entreprise.

TRAITEMENT	BASE LÉGALE	CONSERVATION
Profils clients	<i>Consentement</i>	12 mois après la dernière session, puis archive 6 mois, puis suppression
Signaux d'usage	<i>Intérêt légitime</i>	24 mois, pseudonymisés
Comptes conseillers	<i>Contrat</i>	Durée du contrat, plus 5 ans
Journaux techniques	<i>Intérêt légitime</i>	6 mois glissants

L'inclusion *fait partie* de la conformité.

BIAIS & ÉQUITÉ

Un catalogue à corriger

Le catalogue public penche vers l'Occident. Sans contrôle, les recommandations serviraient mieux certaines carnations et morphologies. La performance est mesurée par tranches et réinjectée dans le ré-entraînement.

LANGUE

Français et anglais

Profils, étiquettes et proposition livrée sont tenus en français et en anglais, sur un vocabulaire unique et normalisé.

ACCESSIBILITÉ

Pour le client final

La proposition respecte des standards de contraste reconnus, porte une alternative textuelle pour chaque image, et s'exporte sur demande dans une forme lisible par lecteur d'écran.

Un risque, *un responsable*.

RISQUE	VRAISEMBLANCE	IMPACT	RESPONSABLE	TRAITEMENT PRINCIPAL
Fuite de profil client	MOYENNE	CRITIQUE	<i>DPO</i>	Chiffrement, isolation, masquage, tests d'intrusion
Défaut d'isolation multi-tenant	MOYENNE	CRITIQUE	<i>CTO / CDO</i>	Sécurité au niveau des lignes, tests d'isolation, audit
Biais issu du jeu initial	ÉLEVÉE	ÉLEVÉ	<i>Data Owner, Modèles</i>	Fiche modèle, mesure par tranches, supervision humaine
Rançongiciel	ÉLEVÉE	CRITIQUE	<i>CISO</i>	Sauvegardes immuables, EDR, exercices de reprise
Qualité d'entrée dégradée	ÉLEVÉE	ÉLEVÉ	<i>Data Owner, Signaux</i>	Barrière qualité, suivi de dérive, retour arrière
Erreur ou usage interne abusif	MOYENNE	ÉLEVÉ	<i>CTO / CDO</i>	Moindre privilège, journalisation, séparation des tâches

Changer les pratiques, *pas seulement les savoirs.*

FORMATION

Ancrée aux décisions

À l'arrivée. Politique, bases du RGPD et de l'AI Act, procédure d'incident, isolation des tenants.

Par métier. Sécurité applicative et donnée hors production côté technique ; conformité en démonstration et devoirs côté conseiller pour le commerce.

Chaque année. Un rappel porté par les incidents de l'année, clos par un court quiz.

PROCESSUS

Le changement profond

Le **consentement** devient une étape de l'accueil du client, non un ajout après coup.

Une **demande de droits** suit un chemin défini, avec un responsable et un délai connus.

Un **déploiement** n'est tenu pour fait qu'une fois sa décision écrite existante. L'efficacité se mesure au nombre d'incidents évitables sur l'année.

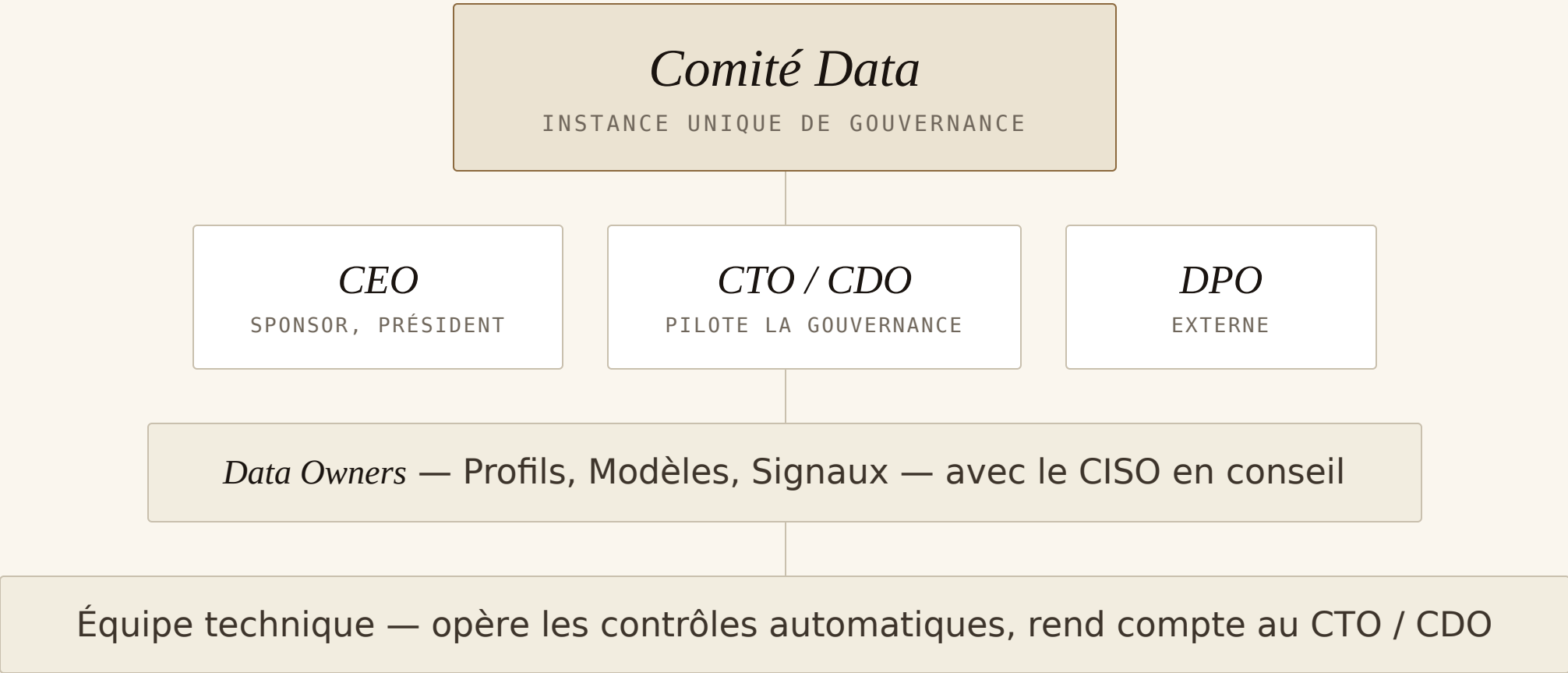
L'ORGANE DE GOUVERNANCE

Deux dimensions, *une responsabilité.*

DIMENSION EXTERNE – LA CHAÎNE DE RESPONSABILITÉ RGPD



DIMENSION INTERNE – L'ORGANE QUI OPÈRE LES CONTRÔLES



RÔLES & RESPONSABILITÉS

Les mêmes rôles, *de bout en bout.*

ACTIVITÉ	CEO	CTO/CDO	DPO	CISO	OWNERS	ÉQUIPE
Définir la politique	A	R	C	C	C	I
Classer la donnée	I	A	C	I	R	R
Piloter la conformité RGPD	I	C	A/R	C	C	I
Traiter une demande de droits	I	I	A/R	I	C	R
Approuver une promotion de modèle	I	A	I	I	R	R
Sécuriser les accès	I	C	C	A/R	I	R
Gérer un incident majeur	A/R	R	R	C	I	R

R réalise · **A** approuve · **C** consulté · **I** informé

Cinq cibles, *année 1.*

Consentements valides sur les clients actifs	$\geq 98 \%$	BASE PROFILS
Délai moyen de réponse aux demandes de droits	$\leq 15 j$	DPO
Ré-entraînements arrêtés sur la qualité	$\leq 5 \%$	PIPELINE
Couverture des tests automatisés	$\geq 80 \%$	INTÉGRATION
Personnel ayant suivi le parcours annuel	100%	DPO

FEUILLE DE ROUTE & MATURITÉ

Des jalons datés, *une trajectoire.*

<i>Jour 15</i>	DPO externe engagé	CEO
<i>Jour 30</i>	Registre et procédure de droits en service	DPO
<i>Jour 45</i>	Analyse d'impact sur les profils achevée	DPO, CTO
<i>Jour 60</i>	Isolation des tenants auditée et testée	CTO, CISO
<i>Jour 90</i>	Première revue du comité, plan d'année 1 arrêté	CEO, CTO
<i>Mois 18</i>	Audit externe, ouverture de la voie ISO 27001	CTO / CDO

Où en est Miroir

Sur une échelle à cinq niveaux, Miroir se situe aujourd'hui à **géré** sur la stratégie, l'organisation et la culture, et entre **défini** et **mesuré** sur la politique, les processus et l'outillage. La cible d'année 1 : atteindre **défini à mesuré** sur tous les axes, sans surinvestissement.